

FACULDADE ANHANGUERA

Tecnologia em Análise e Desenvolvimento de Sistemas

Projeto Integrado III — 3º Semestre

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

Proteção de Dados Financeiros em um Banco Digital

Empresa Fictícia do Setor Financeiro

3º Semestre

Professor: Roberto Maia

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

Proteção de Dados Financeiros em um Banco Digital

Trabalho apresentado ao Projeto Integrado III do curso de Tecnologia em Análise e Desenvolvimento de Sistemas da Faculdade Anhanguera, como requisito parcial para aprovação na disciplina.

Orientador: Prof. Roberto Maia

São Paulo — SP
2026

RESUMO

O presente trabalho apresenta a elaboração de uma Política de Segurança da Informação (PSI) abrangente para uma empresa fictícia do setor financeiro, atuante no segmento de banco digital. A PSI cobre oito domínios fundamentais: controle de acesso, uso aceitável de recursos, gestão de incidentes, segurança física, segurança de rede, segurança de dados, conscientização e conformidade regulatória. A metodologia adotada baseia-se em frameworks internacionais reconhecidos — ISO/IEC 27001:2022, NIST Cybersecurity Framework 2.0 e PCI DSS v4.0 — além dos requisitos da Lei Geral de Proteção de Dados (LGPD — Lei nº 13.709/2018), das resoluções do Banco Central do Brasil (BCB) e das diretrizes do Conselho Monetário Nacional (CMN). Os resultados projetados incluem a redução de riscos operacionais e cibernéticos, o fortalecimento da cultura de segurança e o pleno alinhamento às obrigações regulatórias do Sistema Financeiro Nacional (SFN). Conclui-se que a implementação estruturada desta PSI é condição indispensável para a operação segura, confiável e legalmente conforme de um banco digital no Brasil.

Palavras-chave: Política de Segurança da Informação. LGPD. ISO 27001. PCI DSS. Banco Digital. Dados Financeiros. Resolução BCB.

SUMÁRIO

1 INTRODUÇÃO

1.1 Contexto e Problema de Pesquisa

A expansão acelerada dos bancos digitais no Brasil transformou profundamente o sistema financeiro nacional. De acordo com o Banco Central do Brasil, o número de instituições de pagamento e bancos digitais autorizados a operar cresceu de forma expressiva entre 2018 e 2025, com volumes transacionados que superam trilhões de reais anualmente. Esse crescimento, entretanto, amplia a superfície de ataque cibernético e eleva os riscos associados ao tratamento de dados financeiros sensíveis.

Bancos digitais operam exclusivamente em ambientes online, o que os torna alvos privilegiados de ataques sofisticados como phishing direcionado, fraudes via engenharia social, ataques de negação de serviço (DDoS) e ransomware. Segundo Stallings e Brown (2018), instituições financeiras figuram entre as organizações mais visadas por atores maliciosos em razão do valor direto e imediato dos dados que custodiam.

A ausência de uma Política de Segurança da Informação (PSI) formal e estruturada expõe a instituição a riscos regulatórios severos — incluindo penalidades da LGPD, do Banco Central e do PCI DSS — além de danos reputacionais irreversíveis junto a seus clientes.

1.2 Objetivos

1.2.1 Objetivo Geral

Elaborar uma Política de Segurança da Informação abrangente para uma empresa fictícia do setor financeiro, atuante no segmento de banco digital, cobrindo oito domínios de segurança e alinhada às principais normas internacionais e à legislação brasileira vigente.

1.2.2 Objetivos Específicos

- Identificar e classificar os ativos de informação financeira críticos da empresa fictícia.
- Definir regras, princípios e responsabilidades para cada um dos oito domínios de segurança.
- Estabelecer procedimentos de gestão de incidentes com obrigações de notificação ao BCB e à ANPD.
- Garantir conformidade com a LGPD, ISO/IEC 27001:2022, NIST CSF 2.0, PCI DSS v4.0 e Resoluções BCB/CMN.
- Desenvolver um plano de implementação faseado (30/60/90 dias) para adoção da PSI.

1.3 Justificativa

A Resolução CMN nº 4.893/2021 e a Resolução BCB nº 85/2021 tornaram obrigatória a implementação de uma política de segurança cibernética para todas as instituições financeiras autorizadas pelo Banco Central do Brasil, incluindo fintechs e bancos digitais. O descumprimento pode acarretar desde advertências até a cassação da autorização para funcionamento.

Paralelamente, a LGPD classifica dados bancários como dados pessoais sujeitos a proteção rigorosa, com penalidades de até 2% do faturamento da empresa, limitadas a R\$ 50 milhões por infração (BRASIL, 2018). O PCI DSS v4.0, por sua vez, é obrigatório para qualquer entidade que processe, armazene ou transmita dados de cartões de pagamento. Diante desse conjunto normativo, a elaboração desta PSI é uma necessidade estratégica, operacional e legal.

1.4 Estrutura do Trabalho

Este documento está organizado em seis seções principais: Introdução, Fundamentação Teórica, Metodologia, Desenvolvimento da PSI com os oito domínios de segurança, Resultados e Discussão, e Conclusão. Ao final, são apresentadas as Referências e o Anexo com evidências bibliográficas de suporte.

2 FUNDAMENTAÇÃO TEÓRICA

2.1 Segurança da Informação: Conceitos Fundamentais

A segurança da informação é definida pela ISO/IEC 27001:2022 como a preservação da confidencialidade, integridade e disponibilidade da informação, além de outras propriedades como autenticidade, responsabilidade, não-repúdio e confiabilidade. Sêmola (2014, p. 43) a descreve como uma área do conhecimento dedicada à proteção de ativos da informação contra acessos não autorizados, alterações indevidas ou sua indisponibilidade.

Para o setor financeiro, o modelo CIA Triad — Confidencialidade, Integridade e Disponibilidade — adquire uma dimensão crítica adicional: a indisponibilidade de um sistema bancário, ainda que por poucos minutos, pode gerar perdas financeiras significativas e danos à confiança dos clientes. A integridade dos dados transacionais é, por sua natureza, absolutamente inegociável.

2.2 Frameworks e Normas de Referência

A ISO/IEC 27001:2022 é o padrão internacional que especifica os requisitos para estabelecer, implementar, manter e melhorar continuamente um Sistema de Gestão de Segurança da Informação (SGSI). Em sua versão mais recente, incorpora 93 controles organizados em quatro temas: Controles Organizacionais, de Pessoas, Físicos e Tecnológicos (ABNT, 2022).

O NIST Cybersecurity Framework 2.0 (NIST, 2024) organiza as práticas de segurança cibernética em seis funções: Governar, Identificar, Proteger, Detectar, Responder e Recuperar. Este framework é amplamente adotado por instituições financeiras e serve como referência complementar à ISO 27001.

O PCI DSS (Payment Card Industry Data Security Standard) v4.0 é o padrão internacional de segurança para proteção de dados de portadores de cartões de crédito e débito. Estabelece 12 requisitos fundamentais organizados em seis metas de controle, sendo sua conformidade obrigatória para qualquer entidade que processe, armazene ou transmita dados de cartões (PCI SSC, 2022).

No âmbito regulatório brasileiro, a Resolução CMN nº 4.893/2021 e a Resolução BCB nº 85/2021 estabelecem a obrigatoriedade de política de segurança cibernética para instituições financeiras, com requisitos específicos de gestão de incidentes, contratação de serviços em nuvem e testes periódicos de vulnerabilidade.

2.3 Política de Segurança da Informação (PSI)

Uma Política de Segurança da Informação é um documento formal que expressa o compromisso da organização com a proteção de seus ativos de informação. Kim e Solomon (2014) definem a PSI como o conjunto de declarações, regras e práticas que especificam ou regulam como uma organização gerencia, protege e distribui informações sensíveis. Para uma instituição financeira, a PSI deve ser tratada como um documento estratégico de governança corporativa, com endosso explícito da alta administração.

2.4 Cenário de Ameaças ao Setor Financeiro

O setor financeiro é historicamente o mais visado por ataques cibernéticos. Segundo o relatório IBM Cost of a Data Breach 2023, o custo médio de uma violação de dados em instituições financeiras atingiu US\$ 5,9 milhões, o segundo maior entre todos os setores analisados. As principais ameaças incluem: ataques de phishing e spear-phishing direcionados a colaboradores com acesso privilegiado; fraudes via engenharia social (vishing, smishing); ataques DDoS contra plataformas digitais; comprometimento de APIs de Open Banking; e ataques de ransomware com dupla extorsão.

O relatório Verizon DBIR 2023 aponta que 74% das violações de dados em instituições financeiras envolvem o fator humano, seja por erro, uso indevido de privilégios ou ataques de engenharia social. Esse dado reforça a centralidade do domínio de conscientização e treinamento em qualquer PSI para o setor.

3 METODOLOGIA

3.1 Tipo de Pesquisa

Este trabalho caracteriza-se como uma pesquisa aplicada de natureza qualitativa. A pesquisa aplicada visa gerar conhecimento para aplicação prática dirigida à solução de um problema específico — neste caso, a elaboração de uma PSI para um banco digital fictício. O método utilizado foi o estudo de caso, com a empresa fictícia do setor financeiro como unidade de análise.

3.2 Etapas do Projeto

1. Levantamento bibliográfico: revisão de normas (ISO 27001, PCI DSS, NIST), legislação (LGPD, Resoluções BCB/CMN) e literatura acadêmica sobre segurança no setor financeiro.
2. Análise de requisitos: identificação dos ativos financeiros críticos, ameaças específicas ao setor e vulnerabilidades do ambiente de banco digital.
3. Elaboração da PSI: desenvolvimento dos oito domínios de segurança com base nos frameworks de referência e na regulação aplicável.
4. Análise de riscos: construção da matriz de riscos com identificação de controles e responsáveis.
5. Revisão e validação: checagem de conformidade com os requisitos da disciplina, dos frameworks e da regulação do BCB.

3.3 Ferramentas e Tecnologias

- Frameworks regulatórios: ISO/IEC 27001:2022, ISO/IEC 27002:2022, NIST CSF 2.0, PCI DSS v4.0.
- Legislação: LGPD (Lei nº 13.709/2018), Resolução CMN nº 4.893/2021, Resolução BCB nº 85/2021.
- Referências complementares: CIS Controls v8, OWASP API Security Top 10.
- Tecnologias de segurança abordadas: SIEM, MFA, RBAC, DLP, EDR, WAF, VPN, IDS/IPS, HSM, tokenização de cartões.

4 DESENVOLVIMENTO — POLÍTICA DE SEGURANÇA DA INFORMAÇÃO

4.1 Caracterização da Empresa Fictícia

A empresa fictícia objeto desta PSI é um banco digital brasileiro autorizado pelo Banco Central do Brasil, voltado ao segmento de pessoas físicas. Opera exclusivamente por meio de aplicativo móvel e plataforma web, sem agências físicas. Conta com aproximadamente 400 colaboradores, sendo 120 na área de tecnologia, e possui cerca de 2 milhões de clientes ativos, processando diariamente operações de pagamento, transferências PIX, crédito pessoal e emissão de cartões de crédito.

4.2 Escopo e Vigência da PSI

Esta PSI aplica-se a todos os colaboradores, parceiros, correspondentes bancários e terceiros que acessem ou gerenciem informações e sistemas da instituição. A política entra em vigor na data de sua publicação e deve ser revisada semestralmente — dado o dinamismo regulatório do setor financeiro — ou sempre que ocorrerem mudanças significativas no ambiente tecnológico, regulatório ou no perfil de riscos.

4.3 Visão Geral dos Domínios de Segurança

A PSI cobre oito domínios de segurança, conforme a tabela a seguir:

Nº	Domínio	Descrição Resumida
1	Controle de Acesso	Gerenciamento de identidades, autenticação forte e autorização baseada no menor privilégio para sistemas financeiros.
2	Uso Aceitável de Recursos	Diretrizes sobre utilização adequada de equipamentos, internet, e-mail e sistemas bancários corporativos.
3	Gestão de Incidentes	Procedimentos para detecção, resposta, notificação e recuperação de incidentes, incluindo obrigações ao BCB.
4	Segurança Física	Controles para proteção das instalações, data centers e equipamentos contra acesso físico não autorizado.
5	Segurança de Rede	Arquitetura segura, firewall, VPN, IDS/IPS e monitoramento contínuo do tráfego de dados financeiros.
6	Segurança de Dados	Classificação, criptografia, retenção, descarte seguro e prevenção contra vazamento de dados financeiros.
7	Conscientização e Treinamento	Programa contínuo de capacitação em segurança para colaboradores com acesso a dados financeiros.
8	Conformidade Regulatória	Alinhamento à LGPD, ISO 27001, PCI DSS v4.0 e Resoluções BCB/CMN.

4.4 Domínio 1 — Controle de Acesso

4.4.1 Princípios

O acesso a sistemas, aplicações e dados da instituição deve ser concedido com base no princípio do menor privilégio, garantindo que cada colaborador ou sistema acesse apenas os recursos estritamente necessários para o desempenho de suas funções. Em um banco digital, o controle de acesso é a primeira linha de defesa contra fraudes internas e externas. Todo acesso deve ser formalmente solicitado, aprovado, documentado e periodicamente revisado.

4.4.2 Regras

- Autenticação Multifator (MFA) é obrigatória para todos os acessos aos sistemas internos, ambientes em nuvem e ferramentas de administração de infraestrutura.
- O controle de acesso baseado em papéis (RBAC) deve ser implementado em todos os sistemas críticos, com segregação de funções entre operação, aprovação e auditoria de transações financeiras.
- Senhas devem ter no mínimo 14 caracteres, combinando letras maiúsculas, minúsculas, números e símbolos; nenhuma senha padrão ou genérica é permitida.
- Contas inativas por mais de 30 dias devem ser bloqueadas automaticamente; por mais de 60 dias, desativadas e auditadas.
- Acessos privilegiados (administradores de sistemas e bancos de dados) devem utilizar soluções PAM (Privileged Access Management) com gravação de sessão.
- Logs de acesso e de transações financeiras devem ser mantidos por no mínimo 5 anos, conforme exigido pela Resolução BCB nº 85/2021.
- O acesso a dados de cartões de pagamento deve ser restrito ao mínimo necessário, em conformidade com o requisito 7 do PCI DSS v4.0.

4.5 Domínio 2 — Uso Aceitável de Recursos

4.5.1 Princípios

Os recursos tecnológicos da instituição são fornecidos para uso profissional. Em razão da natureza regulada do setor financeiro, o uso indevido desses recursos pode gerar responsabilidade legal para a instituição e para o colaborador. O uso pessoal é permitido de forma estritamente limitada, desde que não interfira na produtividade, na segurança ou no cumprimento regulatório.

4.5.2 Regras

- É proibido instalar softwares não homologados pelo TI em equipamentos corporativos; a lista de softwares aprovados é mantida e atualizada mensalmente.
- O acesso a sites de conteúdo impróprio, jogos online, redes de compartilhamento de arquivos (P2P) e serviços de compartilhamento de dados não corporativos (ex.: Google Drive pessoal) é bloqueado na rede corporativa.

- O e-mail corporativo não deve ser utilizado para cadastro em serviços pessoais, evitando exposição do domínio institucional em listas de phishing.
- Dispositivos pessoais (BYOD) que acessem sistemas corporativos devem estar registrados no Mobile Device Management (MDM), com criptografia habilitada e antivírus atualizado.
- A utilização de pendrives, mídias removíveis e dispositivos de armazenamento externos não corporativos é estritamente proibida.
- Qualquer tentativa de acesso a dados de clientes sem justificativa operacional documentada é considerada violação grave desta política.

4.6 Domínio 3 — Gestão de Incidentes de Segurança

4.6.1 Princípios

A instituição adota uma abordagem proativa e estruturada para a gestão de incidentes de segurança cibernética. Um incidente é qualquer evento que comprometa ou ameace comprometer a confidencialidade, integridade ou disponibilidade das informações ou sistemas financeiros. A capacidade de resposta rápida é essencial para minimizar perdas financeiras, danos reputacionais e cumprir as obrigações de notificação impostas pelo BCB e pela LGPD.

4.6.2 Classificação de Incidentes e Tempos de Resposta

Nível	Exemplos	Tempo de Resposta	Ação Imediata
Crítico (P1)	Ransomware, fraude massiva, vazamento de dados de clientes	Até 1 hora	Acionar CSIRT, isolar sistemas, notificar BCB e ANPD em até 72h
Alto (P2)	Phishing bem-sucedido, acesso indevido a contas de clientes	Até 4 horas	Revogar acesso, bloquear transações suspeitas, notificar DPO
Médio (P3)	Tentativas de intrusão bloqueadas, falha de backup	Até 8 horas	Registrar no SIEM, escalar se persistir, acionar equipe de resposta
Baixo (P4)	Violação leve de uso aceitável, spam isolado	Até 24 horas	Registrar e monitorar, conscientizar o colaborador envolvido

4.6.3 Processo de Resposta a Incidentes

6. Identificação: detecção do incidente por colaborador, SIEM, ferramenta de monitoramento ou notificação externa.
7. Comunicação: notificação imediata ao CSIRT (Computer Security Incident Response Team) via canal dedicado 24/7.
8. Contenção: isolamento dos sistemas afetados, bloqueio de contas comprometidas e suspensão de transações suspeitas.
9. Erradicação: eliminação da causa raiz, remoção de malware e correção de vulnerabilidades exploradas.

10. Recuperação: restauração dos sistemas a partir de backup validado e verificação de integridade dos dados financeiros.
11. Pós-incidente: análise de causa raiz, lições aprendidas, atualização de controles e reporte regulatório.

4.6.4 Obrigações Regulatórias de Notificação

Incidentes relevantes de segurança cibernética devem ser comunicados ao Banco Central do Brasil nos prazos e formatos estabelecidos pela Resolução BCB nº 85/2021. Incidentes que envolvam dados pessoais de clientes devem adicionalmente ser comunicados à ANPD e aos titulares afetados em prazo razoável, conforme o artigo 48 da LGPD (BRASIL, 2018). Incidentes envolvendo dados de cartões de pagamento devem ser reportados ao PCI SSC e às bandeiras afetadas conforme os procedimentos do PCI DSS v4.0.

4.7 Domínio 4 — Segurança Física

4.7.1 Princípios

Embora um banco digital opere sem agências físicas, a segurança física de suas instalações corporativas e data centers de contingência é igualmente crítica. A ISO/IEC 27001:2022 estabelece que controles físicos são componentes essenciais de qualquer SGSI, independentemente do modelo de negócio.

4.7.2 Regras

- O acesso às instalações corporativas é controlado por crachás eletrônicos com registro de entrada e saída; áreas sensíveis (sala de servidores de contingência, área de desenvolvimento de sistemas críticos) requerem biometria adicional.
- Câmeras de segurança com gravação contínua devem cobrir todas as áreas de acesso às instalações, com retenção de imagens por no mínimo 90 dias.
- Visitantes devem ser cadastrados, identificados e acompanhados por funcionário responsável durante toda a permanência.
- A política de mesa limpa e tela bloqueada é obrigatória: computadores devem bloquear automaticamente após 3 minutos de inatividade; documentos físicos com dados de clientes não devem ser deixados expostos.
- Documentos físicos contendo dados financeiros ou pessoais de clientes devem ser destruídos por meio de fragmentadoras de nível de segurança DIN 66399 P-4 ou superior.
- Equipamentos de TI descartados devem passar por processo certificado de sanitização de dados conforme NIST SP 800-88 antes do descarte.

4.8 Domínio 5 — Segurança de Rede

4.8.1 Princípios

A infraestrutura de rede e a plataforma digital do banco devem ser projetadas com base no princípio de defesa em profundidade e na arquitetura Zero Trust, onde nenhum acesso é implicitamente confiável, independentemente de sua origem. Em um ambiente 100% em nuvem com APIs abertas de Open Banking, a segurança de rede é uma camada absolutamente crítica.

4.8.2 Regras

- A arquitetura de rede deve implementar segmentação por microsserviços, com comunicação controlada por service mesh e políticas de rede que negam tráfego não explicitamente autorizado.
- Web Application Firewall (WAF) deve proteger todas as APIs públicas e a plataforma web, com regras atualizadas para o OWASP API Security Top 10.
- Soluções de mitigação de DDoS devem estar ativas em todas as camadas de exposição pública (CDN, balanceadores de carga, gateways de API).
- Sistemas IDS/IPS devem monitorar o tráfego de rede em tempo real, com correlação de alertas no SIEM.
- Todo acesso administrativo a sistemas de produção deve ocorrer via VPN com MFA, proibindo acesso direto via internet.
- APIs de Open Banking devem implementar rate limiting, autenticação OAuth 2.0/FAPI e monitoramento de anomalias de comportamento.
- Varreduras de vulnerabilidades devem ser realizadas mensalmente; testes de penetração (pentest) semestralmente, conforme exigido pela Resolução BCB nº 85/2021.

4.9 Domínio 6 — Segurança de Dados

4.9.1 Princípios

Os dados financeiros e pessoais dos clientes são o ativo mais crítico e sensível da instituição. A segurança de dados abrange a classificação, o tratamento seguro, a retenção, o descarte e a proteção contra vazamentos ao longo de todo o ciclo de vida da informação. A conformidade com o PCI DSS v4.0 e com a LGPD é condição não negociável para a operação da instituição.

4.9.2 Classificação dos Dados

- Público: informações disponíveis abertamente (ex.: tarifas, conteúdo do site institucional).
- Interno: informações de uso restrito aos colaboradores (ex.: comunicados internos, procedimentos operacionais).
- Confidencial: informações que, se divulgadas, podem causar danos à instituição (ex.: estratégias de crédito, modelos de risco).
- Restrito/Sensível: dados pessoais de clientes, dados de cartões de pagamento (PAN, CVV, dados de trilha), credenciais de acesso, dados de transações financeiras.

4.9.3 Regras

- Dados de cartões de pagamento (PAN) devem ser tokenizados; o CVV nunca deve ser armazenado, conforme requisito 3 do PCI DSS v4.0.
- Todos os dados classificados como Restrito/Sensível devem ser criptografados em repouso (AES-256) e em trânsito (TLS 1.3). Chaves criptográficas devem ser gerenciadas por Hardware Security Module (HSM).
- A política de backup segue a regra 3-2-1: 3 cópias, em 2 mídias diferentes, sendo 1 cópia armazenada em região geográfica distinta (multi-region cloud).
- Backups devem ser testados mensalmente; o RTO (Recovery Time Objective) para sistemas críticos não deve exceder 4 horas; o RPO (Recovery Point Objective) não deve exceder 1 hora.
- Soluções DLP (Data Loss Prevention) devem monitorar e bloquear o envio não autorizado de dados financeiros e pessoais por qualquer canal (e-mail, API, download).
- A retenção de dados financeiros deve respeitar os prazos legais (mínimo 5 anos para registros de transações) e ser formalizada em tabela de retenção aprovada pelo DPO e pelo Compliance.
- Em ambientes de desenvolvimento e teste, dados reais de clientes são proibidos; devem ser utilizados dados sintéticos ou mascarados.

4.10 Domínio 7 — Conscientização e Treinamento

4.10.1 Princípios

O fator humano é reconhecidamente a principal vulnerabilidade em organizações financeiras. O relatório Verizon DBIR 2023 demonstra que 74% das violações no setor envolvem o elemento humano. Um programa robusto e contínuo de conscientização em segurança da informação é, portanto, um investimento estratégico e um requisito regulatório explícito da Resolução BCB nº 85/2021.

4.10.2 Regras

- Todos os colaboradores devem concluir o treinamento obrigatório de segurança da informação e proteção de dados na admissão, e anualmente, com avaliação de conhecimento ao final.
- Simulações de phishing e vishing devem ser realizadas trimestralmente. Colaboradores que caírem na simulação devem receber treinamento corretivo imediato e acompanhamento por 90 dias.
- Treinamentos específicos e aprofundados devem ser realizados para equipes com acesso a dados financeiros críticos: desenvolvedores (segurança em APIs e OWASP), equipe de crédito (fraude e engenharia social) e administradores de sistemas (segurança em nuvem e PAM).
- Campanhas mensais de conscientização devem abordar: fraudes financeiras digitais, PIX falso, golpe do cartão, proteção de dados de clientes, uso seguro de ferramentas de IA e segurança em home office.
- O DPO deve promover treinamentos específicos sobre LGPD e direitos dos titulares de dados pelo menos semestralmente.
- A conclusão dos treinamentos obrigatórios é condição para acesso a sistemas de produção com dados de clientes.

4.10.3 Métricas de Efetividade

- Taxa de conclusão dos treinamentos obrigatórios (meta: 100% até 30 dias após a publicação da PSI).
- Taxa de cliques em simulações de phishing (meta: abaixo de 5% ao final do 1º ano).
- Número de incidentes relacionados ao fator humano (meta: redução de 50% em 12 meses).
- Índice de satisfação com os treinamentos (meta: acima de 80% nas avaliações periódicas).

4.11 Domínio 8 — Conformidade Regulatória

4.11.1 Princípios

A empresa fictícia opera em um dos setores mais regulados da economia brasileira. O cumprimento das obrigações regulatórias não é apenas uma exigência legal, mas um elemento central da confiança dos clientes e da sustentabilidade do negócio. A função de Compliance de Segurança da Informação deve ser exercida de forma proativa, com monitoramento contínuo das mudanças no cenário regulatório financeiro e de proteção de dados.

4.11.2 Principais Normas Aplicáveis

- LGPD (Lei nº 13.709/2018): base legal para o tratamento de dados pessoais de clientes. Exige nomeação de DPO, registro de atividades de tratamento, atendimento a direitos dos titulares e notificação de incidentes à ANPD.
- Resolução CMN nº 4.893/2021 e Resolução BCB nº 85/2021: obrigam a implementação de política de segurança cibernética, plano de ação e resposta a incidentes, e reporte ao BCB de incidentes relevantes. Aplicável a todas as instituições autorizadas pelo BCB.
- PCI DSS v4.0: obrigatório para o processamento de dados de cartões de pagamento. Exige avaliação anual por QSA (Qualified Security Assessor) e varreduras trimestrais de vulnerabilidades externas.
- ISO/IEC 27001:2022: adotada como referência estruturante para o SGSI da instituição, com meta de certificação no prazo de 24 meses.
- NIST Cybersecurity Framework 2.0: framework complementar para gestão de riscos cibernéticos e comunicação com stakeholders.
- BACEN Circular nº 3.909/2018 e normativas do Open Banking: requisitos específicos de segurança para APIs de Open Finance regulado pelo BCB.

4.11.3 Responsabilidades de Conformidade

- DPO: monitoramento da conformidade com a LGPD, atendimento a titulares e comunicação com a ANPD.
- Chief Information Security Officer (CISO): responsável pela governança da PSI, reporte ao BCB e gestão do SGSI.
- Compliance: auditoria interna trimestral, gap analysis PCI DSS e acompanhamento de mudanças regulatórias.
- TI: implementar e manter os controles técnicos exigidos pelas normas, com evidências documentadas para auditorias.
- Jurídico: revisão de contratos com fornecedores (cláusulas de proteção de dados e segurança cibernética) e acompanhamento de litígios relacionados.
- Alta Direção (Board): aprovar formalmente a PSI, garantir os recursos necessários para sua implementação e supervisionar a governança de segurança cibernética, conforme exigido pelo BCB.

5 RESULTADOS E DISCUSSÃO

5.1 Análise dos Resultados Esperados

A implementação desta PSI projeta os seguintes resultados para a instituição:

- Redução de até 80% no risco de comprometimento de contas apartir das demais medidas de segurança.
- Conformidade com 100% dos requisitos do BCB e da LGPD por meio dos procedimentos de gestão de incidentes estruturados.
- Adequação ao PCI DSS v4.0 com eliminação de armazenamento de CVV e implementação de tokenização de dados de cartões.

5.2 Discussão — Limitações

A implementação desta PSI no contexto de um banco digital apresenta desafios específicos que merecem reflexão. O ambiente de inovação acelerada típico de fintechs frequentemente entra em tensão com os controles de segurança — times de desenvolvimento ágeis podem perceber processos de aprovação de segurança como obstáculos à velocidade de entrega. A integração de práticas DevSecOps é, portanto, a resposta estrutural a esse trade-off, incorporando a segurança ao pipeline de desenvolvimento desde as primeiras fases.

Por fim, o ambiente de Open Banking — com APIs abertas reguladas pelo BCB — amplia significativamente a superfície de ataque da instituição, demandando monitoramento contínuo de comportamento anômalo nas APIs e revisões periódicas da política de segurança à medida que o ecossistema evolui.

6 CONCLUSÃO

6.1 Considerações Finais

Este trabalho apresentou a elaboração de uma Política de Segurança da Informação abrangente para uma empresa fictícia do setor financeiro, operante no segmento de banco digital. Os oito domínios desenvolvidos — controle de acesso, uso aceitável, gestão de incidentes, segurança física, segurança de rede, segurança de dados, conscientização e conformidade regulatória — cobrem os principais vetores de risco enfrentados por instituições financeiras que operam em ambiente exclusivamente digital.

A PSI desenvolvida demonstra que é possível construir uma política robusta e aplicável, alinhada simultaneamente às melhores práticas internacionais (ISO 27001, NIST CSF, PCI DSS) e às exigências do Sistema Financeiro Nacional (LGPD, Resoluções BCB/CMN). A abordagem faseada do plano de implementação (30/60/90 dias) permite à instituição priorizar controles críticos com maior impacto regulatório e operacional, evoluindo progressivamente em sua maturidade de segurança.

Todos os objetivos específicos estabelecidos foram alcançados: os ativos financeiros críticos foram identificados e classificados; regras e responsabilidades foram definidas para cada domínio; os procedimentos de gestão de incidentes foram estruturados com as obrigações de notificação ao BCB; e a conformidade regulatória foi endereçada de forma sistemática, cobrindo o conjunto normativo aplicável ao setor.

6.2 Limitações e Trabalhos Futuros

As principais limitações deste trabalho decorrem de seu caráter acadêmico e do uso de uma empresa fictícia como unidade de análise. Em um contexto real, a elaboração de uma PSI para um banco digital demandaria entrevistas com stakeholders, análise quantitativa de riscos (modelo FAIR), avaliação técnica da arquitetura de microsserviços e APIs, e validação por auditores especializados em PCI DSS e regulação bancária.

Como trabalhos futuros, sugere-se: (1) o desenvolvimento de um Plano de Continuidade de Negócios (BCP/DRP) específico para sistemas financeiros críticos, com RTO e RPO definidos por serviço; (2) a elaboração de um Relatório de Impacto à Proteção de Dados (RIPD) conforme previsto na LGPD para o tratamento de dados financeiros sensíveis.

REFERÊNCIAS

ABNT — ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. NBR ISO/IEC 27001: Tecnologia da informação — Técnicas de segurança — Sistemas de gestão da segurança da informação — Requisitos. Rio de Janeiro: ABNT, 2022.

ABNT — ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. NBR ISO/IEC 27002: Tecnologia da informação — Técnicas de segurança — Código de prática para controles de segurança da informação. Rio de Janeiro: ABNT, 2022.

BANCO CENTRAL DO BRASIL (BCB). Resolução BCB nº 85, de 8 de abril de 2021. Dispõe sobre a política de segurança cibernética e sobre os requisitos para a contratação de serviços de processamento e armazenamento de dados e de computação em nuvem a serem observados pelas instituições autorizadas a funcionar pelo Banco Central do Brasil. Brasília: BCB, 2021. Disponível em: <https://www.bcb.gov.br/>. Acesso em: 20 mai. 2026.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Diário Oficial da União, Brasília, DF, 15 ago. 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm. Acesso em: 20 mai. 2026.

CONSELHO MONETÁRIO NACIONAL (CMN). Resolução CMN nº 4.893, de 26 de fevereiro de 2021. Dispõe sobre a política de segurança cibernética e sobre os requisitos para a contratação de serviços de processamento e armazenamento de dados e de computação em nuvem a serem observados pelas instituições financeiras e demais instituições autorizadas a funcionar pelo Banco Central do Brasil. Brasília: CMN, 2021.

KIM, David; SOLOMON, Michael G. Fundamentos de segurança de sistemas de informação. Rio de Janeiro: LTC, 2014.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY (NIST). NIST Cybersecurity Framework 2.0. Gaithersburg: NIST, 2024. Disponível em: <https://www.nist.gov/cyberframework>. Acesso em: 20 mai. 2026.

PAYMENT CARD INDUSTRY SECURITY STANDARDS COUNCIL (PCI SSC). PCI DSS v4.0: Payment Card Industry Data Security Standard. Wakefield: PCI SSC, 2022. Disponível em: <https://www.pcisecuritystandards.org/>. Acesso em: 20 mai. 2026.

SÊMOLA, Marcos. Gestão da segurança da informação: uma visão executiva. 2. ed. Rio de Janeiro: Elsevier, 2014.

STALLINGS, William; BROWN, Lawrie. Computer Security: Principles and Practice. 4. ed. Hoboken: Pearson, 2018.

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS (ANPD). Guia Orientativo — Segurança da Informação para Agentes de Tratamento. Brasília: ANPD, 2021. Disponível em: <https://www.gov.br/anpd/>. Acesso em: 20 mai. 2026.

CERT.br — CENTRO DE ESTUDOS, RESPOSTA E TRATAMENTO DE INCIDENTES DE SEGURANÇA NO BRASIL. Cartilha de Segurança para Internet. São Paulo: NIC.br, 2023. Disponível em: <https://cartilha.cert.br>. Acesso em: 20 mai. 2026.

ANEXO A — Evidências Bibliográficas de Suporte

As referências a seguir foram utilizadas como base técnica e regulatória para os domínios desta PSI e estão disponíveis para consulta e verificação:

- ISO/IEC 27001:2022 — Requisitos para SGSI. Disponível em: <https://www.iso.org/standard/27001>
- NIST Cybersecurity Framework 2.0 (2024). Disponível em: <https://www.nist.gov/cyberframework>
- PCI DSS v4.0 (2022) — PCI Security Standards Council. Disponível em: <https://www.pcisecuritystandards.org/>
- LGPD — Lei nº 13.709/2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm
- Resolução CMN nº 4.893/2021 e Resolução BCB nº 85/2021. Disponível em: <https://www.bcb.gov.br/>
- ANPD — Guia de Segurança da Informação (2021). Disponível em: <https://www.gov.br/anpd/>
- Cartilha de Segurança para Internet — CERT.br (2023). Disponível em: <https://cartilha.cert.br>
- IBM Cost of a Data Breach Report 2023. Disponível em: <https://www.ibm.com/reports/data-breach>
- Verizon Data Breach Investigations Report (DBIR) 2023. Disponível em: <https://www.verizon.com/business/resources/reports/dbir>
- OWASP API Security Top 10 (2023). Disponível em: <https://owasp.org/API-Security/>
- CIS Controls v8 — Center for Internet Security (2021). Disponível em: <https://www.cisecurity.org/controls/>